

CISSP Printable Practice Exam 02 - Domain 2 - Asset Security

Domain 2

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-025)

Scenario: A regional manufacturer is classifying the configuration files used by its automated production lines. Unauthorized disclosure would reveal little of value, but unauthorized modification or loss of availability could stop production and create unsafe operating conditions.

What is the BEST basis for assigning the classification and handling requirements for these files?

- A. Classify them at a low level because their confidentiality impact is limited.
- B. Classify them according to the highest relevant business impact, including integrity and availability.
- C. Use the classification assigned to the servers on which the files are stored.
- D. Delay classification until a production interruption demonstrates the actual impact.

Question 2 (CISSP1-026)

Scenario: During an access review, the infrastructure team asks whether archived customer records may be made available to a new analytics group. The infrastructure team operates the storage platform, while the customer-service executive is accountable for the records and their business use.

Who should make the authorization decision?

- A. The data custodian, because that role implements storage and access controls
- B. The data owner, because that role determines classification and authorized use
- C. The data processor, because that role performs operations on the records
- D. The data steward, because that role maintains data definitions and quality

Question 3 (CISSP1-027)

Scenario: A public-sector research unit combines three datasets that are each approved for internal use. The merged dataset makes it possible to infer the identities and locations of individuals, even though none of the source datasets reveals both elements by itself.

What should the security manager do FIRST?

- A. Retain the internal-use label because every source dataset already has that label.
- B. Reassess the merged dataset and assign handling requirements based on the new aggregate sensitivity.
- C. Remove the source labels because aggregation creates a new asset with no inherited restrictions.
- D. Permit unrestricted sharing until the data owner documents a confirmed disclosure event.

Question 4 (CISSP1-028)

Scenario: An engineering firm permits restricted design documents to be viewed only in managed environments. A project leader wants to send one of these documents to an approved contractor whose personal file-sharing account is convenient but is not covered by the firm's handling standard.

What is the BEST response?

- A. Allow the transfer because the contractor is already approved for the project.
- B. Lower the document's classification temporarily so the transfer can proceed.
- C. Use an approved transfer method that enforces the document's existing handling requirements.
- D. Send the document after the contractor agrees verbally not to redistribute it.

Question 5 (CISSP1-029)

Scenario: A subscription service determines why and how customer profile data will be used. It hires a service provider to process that data solely under documented instructions. The organization is defining responsibilities before the service begins.

Which TWO responsibility assignments are most appropriate? Select 2 of the 5 options below.

- A. The subscription service, as data controller, determines the purposes and essential means of processing.
- B. The service provider, as data processor, may independently expand the processing purpose when it improves efficiency.
- C. The service provider, as data processor, follows documented instructions and applies the required safeguards.
- D. The data custodian becomes the controller because it operates the storage infrastructure.
- E. The business owner transfers all accountability for the data when the processing contract is signed.

Question 6 (CISSP1-030)

Scenario: A logistics company receives network-connected warehouse scanners that must be placed into service quickly. The devices arrive with vendor defaults, unverified software versions, and no entries in the organization's asset inventory.

What should occur BEFORE the scanners are connected to the production network?

- A. Record, validate, securely configure, and formally authorize the devices through the provisioning process.
- B. Connect the devices temporarily and document them after operational testing is complete.
- C. Allow warehouse supervisors to select settings because they understand the workflow.
- D. Rely on the vendor defaults until the first scheduled annual control review.

Question 7 (CISSP1-031)

Scenario: A financial cooperative keeps every customer document indefinitely because storage is inexpensive. Counsel confirms that several record categories have defined minimum retention periods, but no requirement applies after those periods and the business has no documented continuing need.

Which recommendation BEST reduces risk while meeting obligations?

- A. Keep all records indefinitely to maximize the information available for future analysis.
- B. Delete every record immediately after the legal minimum period, regardless of other needs.
- C. Create category-specific schedules that retain records only for validated legal and business needs, then dispose of them securely.
- D. Let each employee decide when records under that employee's control no longer appear useful.

Question 8 (CISSP1-032)

Scenario: A laboratory employee transfers to a nontechnical department. The identity system updates the employee's primary job role, but specialized software licenses, laboratory devices, local data copies, and issued media remain assigned to the employee.

What is the MOST important improvement to the asset lifecycle process?

- A. Wait for the annual inventory so the remaining assets can be reconciled in one batch.
- B. Trigger a role-change workflow that reviews, revokes, returns, sanitizes, or reassigns all associated assets.
- C. Ask the employee to retain the assets in case the original department needs temporary assistance.
- D. Update only the software inventory because physical assets are controlled by building access.

Question 9 (CISSP1-033)

Scenario: A construction company receives notice of litigation involving one completed project. Its approved schedule calls for routine deletion of project correspondence at the end of the month, including messages related to that project.

What should the records manager do FIRST?

- A. Suspend disposition for records within the hold's scope and preserve them in a controlled manner.
- B. Suspend deletion of every record in the company until the litigation is fully resolved.
- C. Continue the approved schedule because changing it would make retention inconsistent.
- D. Allow project staff to choose which messages appear relevant enough to preserve.

Question 10 (CISSP1-034)

Scenario: An educational institution discovers that departments independently acquire software, keep unsupported versions, and retain installation packages after the related systems are retired. Security cannot reliably determine which applications are authorized or still required.

Which control would BEST address the underlying problem?

- A. A centralized software asset lifecycle process covering approval, inventory, maintenance, and retirement
- B. A quarterly reminder asking employees to remove applications they no longer use
- C. A larger storage allocation so departments can preserve every software version
- D. An incident response procedure focused on malware found on unsupported systems

Question 11 (CISSP1-035)

Scenario: A health-research organization must provide a limited dataset to an external research partner for an approved study. The complete internal dataset contains additional sensitive fields that the partner does not need.

Which approach BEST addresses security during the sharing stage of the data lifecycle?

- A. Provide the complete dataset because contractual approval establishes a trusted relationship.
- B. Share only the necessary fields through an approved channel under documented use and handling restrictions.
- C. Move the complete dataset to an archive before giving the partner access to it.

D. Allow the partner to select and delete unnecessary fields after receiving the complete dataset.

Question 12 (CISSP1-036)

Scenario: A defense supplier plans to release failed solid-state drives that held highly sensitive design data to an external recycling firm. The drives cannot be reliably accessed to perform or verify a supported purge operation.

What is the MOST appropriate disposition method?

- A. Clear the drives using a standard file-deletion utility.
- B. Reformat the drives and confirm that no filenames remain visible.
- C. Physically destroy the drives using an approved, verifiable process before release.
- D. Transfer the drives intact after obtaining a confidentiality agreement from the recycler.

Question 13 (CISSP1-037)

Scenario: A consulting firm labels client reports as restricted, yet employees can still copy report contents into personal webmail or removable media. Management wants a control that can identify the sensitive content and enforce policy at common exit points.

Which technology BEST meets this requirement?

- A. Digital rights management that controls permitted use of designated documents
- B. Data loss prevention that inspects content and applies policy to attempted transfers
- C. A cloud access security broker limited to inventorying sanctioned cloud subscriptions
- D. A records archive that preserves reports after their active use ends

Question 14 (CISSP1-038)

Scenario: A media company is adopting multiple cloud collaboration services. It needs visibility into cloud use, enforcement of data-handling policy when users upload sensitive material, and persistent restrictions on how authorized recipients can use selected documents after delivery.

Which THREE controls most directly address these requirements? Select 3 of the 5 options below.

- A. A cloud access security broker for visibility and policy enforcement across cloud services
- B. Data loss prevention for detecting sensitive content and controlling uploads
- C. Digital rights management for persistent restrictions on designated documents
- D. A longer retention schedule for all collaboration records
- E. A hardware inventory reconciliation for employee workstations

Question 15 (CISSP1-039)

Scenario: A utility company applies a corporate data-protection baseline to office systems and an operational analytics platform. One baseline control cannot be implemented on the analytics platform as written because it would interrupt time-critical processing. The data remains sensitive while being processed.

What should the security architect recommend?

- A. Exclude the platform from the baseline because availability has priority in operational environments.
- B. Accept the missing control informally because the platform team understands the

operational risk.

C. Tailor the control through the approved risk process and implement compensating protection that meets the security objective.

D. Apply the control unchanged and treat any processing interruption as an operational issue.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-025) - Correct: B

Classification should reflect all relevant impact dimensions, not confidentiality alone. The severe integrity and availability consequences justify handling requirements aligned with the highest applicable business impact. Inheriting a server label may ignore the files' actual value, and waiting for an incident is reactive rather than risk-based.

Question 2 (CISSP1-026) - Correct: B

The data owner is accountable for determining appropriate use, classification, and access to the records. The custodian implements the approved controls but should not independently authorize a new business use. A processor handles data on another party's behalf, while a steward generally supports quality, definitions, and governance execution rather than owning this authorization decision.

Question 3 (CISSP1-027) - Correct: B

Aggregation can create sensitivity that is not present in the individual sources, so the merged asset requires a new classification assessment before use or sharing. Simply retaining or removing the original labels fails to evaluate the inference risk. Waiting for an actual disclosure would expose the organization to avoidable harm.

Question 4 (CISSP1-028) - Correct: C

Authorization to participate in a project does not remove the handling controls attached to a restricted asset. The transfer should use an approved method that maintains those controls. Convenience, a temporary relabeling, or a verbal assurance does not provide the required protection or formally change the asset's sensitivity.

Question 5 (CISSP1-029) - Correct: A, C

The controller determines the purposes and essential means of processing, while the processor acts on the controller's documented instructions and implements required protections. A processor cannot unilaterally create a new purpose merely for efficiency. Operating storage does not by itself make a custodian the controller, and contracting does not eliminate the organization's accountability.

Question 6 (CISSP1-030) - Correct: A

Secure provisioning establishes inventory, validates the asset and its software, applies approved configurations, and authorizes deployment before production exposure. Connecting first creates an unmanaged risk window. Operational knowledge does not replace security baselines, and vendor defaults should not be assumed to meet organizational requirements.

Question 7 (CISSP1-031) - Correct: C

Category-specific schedules provide a defensible balance among legal, regulatory, contractual, and documented business needs while limiting unnecessary exposure. Indefinite retention enlarges the breach, discovery, and management burden. Automatic deletion at the minimum may ignore valid holds or business needs, while individual discretion produces inconsistent and unauditable outcomes.

Question 8 (CISSP1-032) - Correct: B

A role change should trigger coordinated deprovisioning across logical, physical, software, media, and data assets. This reduces excess access, licensing, loss, and data-exposure risks promptly. Annual reconciliation is too late, retaining assets for convenience preserves unnecessary risk, and building access does not adequately control assigned devices or local copies.

Question 9 (CISSP1-033) - Correct: A

A legal hold overrides normal disposition for records within its defined scope, which must be identified and preserved under controlled procedures. Freezing all organizational records is unnecessarily broad unless the hold requires it. Continuing deletion risks spoliation, while leaving relevance decisions solely to project staff produces incomplete and inconsistent preservation.

Question 10 (CISSP1-034) - Correct: A

The root issue is missing governance across acquisition, deployment, maintenance, and retirement. A centralized lifecycle process creates authoritative inventory and control over authorization and support status. Reminders depend on inconsistent individual action, additional storage reinforces over-retention, and incident response treats consequences rather than the provisioning problem.

Question 11 (CISSP1-035) - Correct: B

The best approach combines data minimization with an approved transfer path and explicit use and handling constraints. A trusted or contracted recipient should still receive only what is necessary. Archiving does not reduce the disclosed content, and asking the recipient to remove excess fields exposes those fields before minimization occurs.

Question 12 (CISSP1-036) - Correct: C

Because the media is leaving organizational control, contains highly sensitive data, and cannot be reliably purged, approved physical destruction provides the appropriate assurance against remanence. File deletion and reformatting are forms of logical clearing that may leave recoverable data. A confidentiality agreement does not substitute for sanitization.

Question 13 (CISSP1-037) - Correct: B

Data loss prevention is designed to discover sensitive content and monitor or block its movement through endpoints, messaging, and network channels according to policy. Digital rights management can constrain use of protected files but is not the best general control for inspecting copied content across exit points. Cloud inventory and archiving address different lifecycle needs.

Question 14 (CISSP1-038) - Correct: A, B, C

A cloud access security broker provides cloud-use visibility and policy enforcement, data loss prevention detects sensitive content and can restrict uploads, and digital rights management maintains usage restrictions on protected documents. Extending retention does not control current cloud movement or recipient actions, and workstation inventory does not directly address the stated data-protection requirements.

Question 15 (CISSP1-039) - Correct: C

Control tailoring should occur through an authorized, documented risk process and preserve the original protection objective through suitable compensating measures. A blanket exclusion or informal acceptance leaves sensitive data in use inadequately governed. Applying the baseline without considering operational constraints may create unacceptable availability consequences rather than balancing the full risk context.